

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 20

Domain IV - Incident Management

43 Questions	69 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 69 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM5-108)

Scenario: An agricultural cooperative detects unauthorized commands sent to crop-spraying drones overnight. Only the operations vice president may suspend the fleet, and that person cannot be reached.

Which readiness improvement would BEST address the delay?

- A. Require flights to continue until the vice president returns.
- B. Document risk-based suspension authority, limits, alternates, and escalation paths.
- C. Allow every employee to disable all agricultural systems permanently.
- D. Transfer all fleet-risk decisions to the drone maintenance vendor.

Question 2 (CISM5-109)

Which development is the STRONGEST trigger for an immediate incident-response plan review?

- A. A team changes its weekly meeting agenda.
- B. A dashboard receives a new color palette.
- C. A low-impact office utility receives a routine update.
- D. An acquisition changes regulated services, reporting lines, suppliers, and escalation contacts.

Question 3 (CISM5-110)

Scenario: Two companies operate a shared research platform through a joint venture. Their plans assign conflicting incident commanders and do not define who may isolate shared infrastructure.

What governance mechanism should be established before operations expand?

- A. Separate command structures that exchange information only after closure.
- B. A rule that the first analyst to see an alert controls both companies.
- C. A joint response model defining accountable ownership, isolation authority, information flow, and escalation.
- D. Automatic public disclosure by either company without coordination.

Question 4 (CISM5-111)

Scenario: A regional publisher has separate cyber, crisis, continuity, and disaster-recovery plans. They use different severity terms, contacts, and activation thresholds.

Which action provides the GREATEST readiness improvement?

- A. Create common governance, activation interfaces, decision authority, and tested handoffs across the plans.
- B. Let each plan owner retain incompatible terminology.
- C. Assign internal audit to lead every operational response.
- D. Add more malware indicators to the cyber plan.

Question 5 (CISM5-112)

Scenario: An architecture firm identifies its design repository as critical but omits identity, licensing, rendering, and wide-area connectivity dependencies.

What is the MOST significant consequence?

- A. Recovery sequencing may fail because required supporting services are absent.
- B. The repository hardware may be overinsured.
- C. The incident log may contain too many entries.
- D. Every repository alert will necessarily become a disaster.

Question 6 (CISM5-113)

Scenario: A retailer's gift-card activation service has moderate impact most months but becomes essential during the final week of the year.

How should readiness planning reflect this pattern?

- A. Use only average annual transaction volume.
- B. Use time-sensitive priority, staffing, escalation, and recovery requirements for the peak period.
- C. Rate every gift-card event at maximum severity all year.
- D. Set priority from the number of servers alone.

Question 7 (CISM5-114)

Scenario: A legal-services company has a four-hour recovery time objective for electronic filings but has never approved how much newly submitted filing data may be lost.

Which requirement should management define?

- A. A target number of security alerts per day.
- B. A standard attendance level for tabletop exercises.
- C. A maximum duration for responder interviews.
- D. A recovery point objective based on acceptable loss of filing transactions.

Question 8 (CISM5-115)

What is the PRIMARY purpose of coordinating business continuity with incident response?

- A. To transfer investigation ownership to business staff.
- B. To sustain prioritized activity while containment, recovery, and restoration proceed.
- C. To replace containment with manual processing.
- D. To activate alternate sites for every security event.

Question 9 (CISM5-116)

Scenario: A remote-work continuity plan uses a virtual workspace that authenticates through the same identity platform likely to be disabled during privileged-account compromise.

Which recommendation is BEST?

- A. Increase identity log retention without changing access.
- B. Accept the design because the workspace is externally hosted.
- C. Develop and test an alternate access method that does not depend on the affected identity platform.
- D. Delay all continuity activity until the identity service returns.

Question 10 (CISM5-117)

Scenario: A diagnostic laboratory's paper-result process supports 10 percent of normal volume, while the approved minimum during an outage is 50 percent.

What should occur NEXT?

- A. Redesign and exercise the process to meet the approved requirement or formally address the gap.
- B. Lower the minimum without clinical-owner approval.
- C. Approve the process because some results can be recorded.
- D. Wait for an outage to learn whether the shortfall matters.

Question 11 (CISM5-118)

Scenario: A subscription company plans to recover customer applications before the secrets vault required to retrieve their database credentials.

How should the restoration order be changed?

- A. Give all components the same recovery point objective.
- B. Recover the most visible application first regardless of prerequisites.
- C. Restore the secrets vault before applications that depend on it.
- D. Let each application team choose independently.

Question 12 (CISM5-119)

Scenario: A cooperative restores virtual servers during a disaster-recovery test but does not test user access, data integrity, payment interfaces, or member transactions.

What should the next test include?

- A. Only host startup times.
- B. End-to-end validation of access, data, interfaces, transactions, dependencies, and recovery objectives.
- C. A review of office furniture at the alternate site.
- D. A larger inventory of backup media.

Question 13 (CISM5-120)

Which statement correctly distinguishes RTO from RPO?

- A. RTO measures lost data, while RPO measures staff availability.
- B. RTO addresses acceptable restoration time, while RPO addresses acceptable data loss measured in time.
- C. Both terms describe the maximum length of an investigation.
- D. Both terms are always identical to supplier service levels.

Question 14 (CISM5-121)

Scenario: A consulting firm ranks incidents by device count. Access to one executive merger mailbox is rated below nuisance software on hundreds of lobby tablets.

Which severity-model change is MOST appropriate?

- A. Base severity only on hardware replacement cost.
- B. Let each responder choose a rating without criteria.
- C. Include information sensitivity, strategic impact, trust, scope, urgency, and applicable obligations.
- D. Assign maximum severity to every mailbox alert.

Question 15 (CISM5-122)

Scenario: A hospitality group instructs responders to escalate when an incident feels serious. Exercises show inconsistent involvement of privacy, franchise, and executive leaders.

Which escalation rule should replace this subjective instruction?

- A. Escalation only after financial loss is final.
- B. Escalation whenever any user requests it.
- C. Documented thresholds based on impact, data, scope, urgency, safety, and obligations.
- D. Board escalation for every blocked alert.

Question 16 (CISM5-123)

Scenario: A media service labels outages, content manipulation, privacy events, and account misuse as urgent without distinguishing response expertise or decision authority.

Which redesign is BEST?

- A. Separate category and severity, then map their combinations to owners, actions, authority, and escalation.
- B. Create one severity for every content title.
- C. Use estimated repair hours as the sole field.
- D. Retain one label and add more email recipients.

Question 17 (CISM5-124)

Scenario: A logistics exercise reveals no alternate incident commander, no customs liaison, and no leader trained to brief the board. Technical responders perform well.

What should be prioritized?

- A. Map competencies to roles, assign trained personnel and alternates, and retest the gaps.
- B. Remove customs and board injects from later tests.
- C. Ask a carrier to make all corporate decisions.
- D. Teach board members to analyze malware.

Question 18 (CISM5-125)

Scenario: A lender repeats the same announced tabletop each quarter. Participants know the inject order and read prepared answers without discussing tradeoffs.

How should this predictable exercise program be improved?

- A. Stop documenting results because performance is consistent.
- B. Score only the speed of alert recognition.
- C. Use varied scenarios and injects tied to decision, coordination, communication, and recovery objectives.
- D. Exclude business leaders to shorten the session.

Question 19 (CISM5-126)**Which exercise is BEST for assessing executive decisions without disrupting production?**

- A. A facilitated tabletop with progressive business and stakeholder injects.
- B. A routine vulnerability scan.
- C. An unannounced shutdown of live systems.
- D. A count of employees who downloaded the plan.

Question 20 (CISM5-127)

Scenario: A broadcasting company's simulation report lists delayed decisions but provides no owners, deadlines, acceptance criteria, or follow-up test.

Which follow-up is MOST appropriate?

- A. Delete difficult observations before leadership review.
- B. Create prioritized corrective actions with owners, dates, validation evidence, and retesting.
- C. Use attendance as the only success measure.
- D. Approve the plan because the simulation ended.

Question 21 (CISM5-128)

Which initial determination should triage produce?

- A. A completed root-cause analysis.
- B. A final external notification package.
- C. An initial determination of incident status, impact, priority, ownership, and routing.
- D. A permanent redesign of affected systems.

Question 22 (CISM5-129)

Scenario: A pediatric clinic receives reports of blocked scans and unexplained changes in telemetry thresholds used to alert nurses.

Which report needs FIRST assessment?

- A. The scans because they contain more events.
- B. The telemetry changes because possible integrity and patient-safety impact require urgent triage.
- C. Neither until malicious intent is proven.
- D. Both after the next scheduled meeting.

Question 23 (CISM5-130)

Scenario: Small suppliers report suspicious portal activity to whichever buyer they know. Reports are often delayed when buyers are traveling.

Which supplier-reporting improvement is MOST appropriate?

- A. Require suppliers to prove compromise before reporting.
- B. Provide a monitored supplier-reporting channel with acknowledgment, intake guidance, and escalation.
- C. Ask buyers to conduct forensic analysis.
- D. Ignore reports from suppliers below a spending threshold.

Question 24 (CISM5-131)

Scenario: A food-processing controller is issuing unsafe temperature commands. Emergency isolation will stop production and may overwrite volatile diagnostic data.

Which action should be supported FIRST?

- A. Place the process in a safe state using authorized procedures, document actions, and preserve feasible evidence.
- B. Continue unsafe production until all data is collected.
- C. Erase the controller without recording the action.
- D. Wait for the equipment vendor to decide whether safety matters.

Question 25 (CISM5-132)

Scenario: Evidence suggests a database administrator may have concealed unauthorized queries. The administrator's manager proposes that the administrator collect and interpret all logs.

What is the BEST governance response?

- A. Assign independent investigators, control access as authorized, and coordinate with legal and human resources.
- B. Stop the inquiry unless the administrator agrees.
- C. Accept a verbal summary from the administrator.
- D. Publicly name the administrator before validation.

Question 26 (CISM5-133)

Scenario: After suspected procurement fraud, teams copy invoice records to personal drives without recording source, collection time, hashes, custodians, or transfers.

What is the PRIMARY chain-of-custody concern?

- A. The records necessarily identify the wrong employee.
- B. Every recovery objective must be shortened.
- C. The incident automatically becomes a disaster.
- D. Evidence integrity and provenance may be challenged because custody was not maintained.

Question 27 (CISM5-134)

Scenario: A global company plans to image employee-owned devices in several countries after suspected design-file theft. Local rules differ.

Which coordination step should occur before device collection?

- A. Coordinate legal, privacy, human resources, and investigators on lawful, proportionate collection and preservation.
- B. Let local supervisors decide legal authority individually.
- C. Notify the suspected individuals publicly.
- D. Collect every device immediately under one global rule.

Question 28 (CISM5-135)

Which factor should MOST influence selection of a containment strategy?

- A. The balance among continuing harm, safety, business impact, evidence, authority, and recovery options.
- B. The personal preference of the first analyst.
- C. The action used in the previous incident.
- D. The length of the technical procedure.

Question 29 (CISM5-136)

Scenario: A benefits platform confirms abuse of one broker API key. Disabling the full API would interrupt enrollment for thousands of unrelated customers.

Which targeted containment action is BEST for this API incident?

- A. Disable the entire platform without assessing narrower options.
- B. Leave the key active until enrollment closes.
- C. Revoke the affected key, isolate the broker connection, preserve records, and monitor for related abuse.
- D. Delete API logs before isolation.

Question 30 (CISM5-137)

Scenario: A theater chain cannot replace unsupported ticket scanners for two months. Segmentation and supervised updates reduce exposure but slow entry.

Which strategy is MOST appropriate?

- A. Restore unrestricted connectivity to improve speed.
- B. Implement tested, monitored, business-approved restrictions with an expiration date and tracked replacement.
- C. Accept the exposure indefinitely without approval.
- D. Disconnect every scanner without considering crowd safety.

Question 31 (CISM5-138)

Scenario: Social posts claim a membership association lost all identity records. Responders have confirmed service disruption but no data loss.

Which communication is MOST appropriate?

- A. Issue an approved holding statement describing verified impact, response activity, and update channels.
- B. Publish investigators' competing theories.
- C. Remain silent until every corrective action is complete.
- D. Confirm the rumored loss to appear decisive.

Question 32 (CISM5-139)

Scenario: A cloud provider discovers possible exposure involving customers in multiple jurisdictions. The affected data and customer list are still being refined.

What should be initiated FIRST?

- A. A delay until final root-cause analysis.
- B. One universal deadline copied from an unrelated rule.
- C. A statement that every customer suffered identity theft.
- D. A coordinated legal, privacy, contract, insurance, and business assessment of verified facts and applicable duties.

Question 33 (CISM5-140)

Scenario: During a service-integrity incident, executives receive raw logs while engineers receive only financial-impact estimates.

Which reporting improvement is BEST?

- A. Send identical raw detail to every recipient.
- B. Allow teams to publish independent estimates.
- C. Create audience-specific updates from one verified incident record, aligned with decision needs and cadence.
- D. Stop scheduled updates and answer only questions.

Question 34 (CISM5-141)

Scenario: A cyber incident disrupts emergency housing placement across several municipalities during severe weather. Routine technical calls exclude crisis leaders and public affairs.

Which action is required NEXT?

- A. Wait for final technical root cause.
- B. Allow individual analysts to brief the public.
- C. Close the incident because housing teams own service delivery.
- D. Activate crisis coordination for operational, executive, government, partner, and public communication needs.

Question 35 (CISM5-142)

Scenario: A design firm removes a malicious extension, but investigators find active unauthorized sessions and a compromised recovery email address.

What should occur before restoring normal access?

- A. Declare eradication complete because the extension is gone.
- B. Restore access and address sessions later.
- C. Close the incident and treat the email issue as routine support.
- D. Revoke unauthorized sessions, secure recovery paths, remediate the weakness, and validate removal of persistence.

Question 36 (CISM5-143)

What is the PRIMARY purpose of validating a recovered service?

- A. To prove no future incident can occur.
- B. To confirm functionality, integrity, security, dependencies, and agreed business outcomes before normal use.
- C. To remove the need for enhanced monitoring.
- D. To transfer acceptance authority to a vendor.

Question 37 (CISM5-144)

Scenario: A billing service is available after unauthorized account changes, but balances do not reconcile with the authoritative ledger.

Which return-to-normal decision is BEST?

- A. Resume billing because infrastructure tests pass.
- B. Declare success solely because the RTO was reached.
- C. Let the hosting supplier accept the discrepancy.
- D. Maintain restrictions until reconciliation and recovery criteria are satisfied and the designated business owner accepts service.

Question 38 (CISM5-145)

Scenario: An online marketplace restores access after token theft. Credentials were reset, persistence checks passed, and service validation succeeded.

What should the incident manager authorize NEXT?

- A. Disable logging to improve performance.
- B. Immediately delete all incident indicators.
- C. Restore service gradually with enhanced recurrence monitoring
- D. Keep the service offline until all enterprise risk disappears.

Question 39 (CISM5-146)

Scenario: A voice-assistant integration disclosed internal scheduling data after crafted spoken requests. Existing assessments and exercises cover only typed inputs.

Which post-incident improvement package is BEST?

- A. Document the event but retain existing assumptions.
- B. Permanently ban all voice technology without business analysis.
- C. Rely only on employee reminders.
- D. Reassess the risk, revise response criteria and safeguards, train relevant roles, and test voice-channel scenarios.

Question 40 (CISM5-147)

Scenario: After accidental data publication, an executive wants the review limited to identifying the employee who clicked approve.

How should the information security manager structure the review?

- A. Exclude process owners.
- B. Begin by publicly naming the employee.
- C. Examine design, approvals, workload, training, oversight, and contributing factors while using proper personnel channels.
- D. Cancel the review because human error was involved.

Question 41 (CISM5-148)

Scenario: A scheduling service failed when a shared integration certificate expired. Renewal ownership was undefined, notices went to an abandoned mailbox, and no escalation existed.

Which finding BEST states the root cause?

- A. The help desk received many calls.
- B. Users saw error messages.
- C. Responders restarted application servers.
- D. Certificate governance failed in ownership, renewal, and escalation

Question 42 (CISM5-149)

Scenario: Months after a supplier incident, recommendations remain in meeting notes without owners, deadlines, evidence, or exception approval.

Which mechanism should be implemented?

- A. A governed corrective-action register with ownership, priority, dates, validation, escalation, and formal risk acceptance.
- B. Automatic closure after a fixed number of months.
- C. Progress review limited to original responders.
- D. Verbal completion claims without evidence.

Question 43 (CISM5-150)

Scenario: A software cooperative reports only incident counts. Leadership cannot see whether impact, detection time, recurrence, recovery, or overdue actions are improving.

Which metric set provides the MOST useful insight?

- A. Impact, response, recurrence, recovery, and remediation trends
- B. Only responder labor hours.
- C. Only incidents marked closed.
- D. Only alerts generated per tool.

Answer Key

Domain IV - Incident Management

1 B	2 D	3 C	4 A	5 A
6 B	7 D	8 B	9 C	10 A
11 C	12 B	13 B	14 C	15 C
16 A	17 A	18 C	19 A	20 B
21 C	22 B	23 B	24 A	25 B
26 D	27 A	28 A	29 C	30 B
31 A	32 D	33 C	34 D	35 D
36 B	37 D	38 C	39 D	40 C
41 D	42 D	43 A		

Detailed Explanations

Question 1 (CISM5-108)

Correct answer: B - Document risk-based suspension authority, limits, alternates, and escalation paths.

Bounded delegation enables timely containment while preserving accountability. Waiting permits potential harm, unrestricted authority is excessive, and a vendor cannot assume the cooperative's final risk decision.

Question 2 (CISM5-109)

Correct answer: D - An acquisition changes regulated services, reporting lines, suppliers, and escalation contacts.

An acquisition can invalidate scope, ownership, dependencies, contacts, and obligations. Meeting formats, presentation colors, and routine low-impact updates do not materially alter response governance.

Question 3 (CISM5-110)

Correct answer: C - A joint response model defining accountable ownership, isolation authority, information flow, and escalation.

A joint model resolves authority and coordination before an incident occurs. Separate command delays decisions, initial detection does not confer enterprise authority, and uncoordinated disclosure can conflict with verified facts and obligations.

Question 4 (CISM5-111)

Correct answer: A - Create common governance, activation interfaces, decision authority, and tested handoffs across the plans.

Common governance and tested interfaces prevent conflicting activation and ownership. More indicators do not resolve coordination, incompatible terms preserve ambiguity, and internal audit should not assume operational command.

Question 5 (CISM5-112)

Correct answer: A - Recovery sequencing may fail because required supporting services are absent.

A critical service cannot be restored effectively without its prerequisites. Log volume and insurance are unrelated, and missing dependencies do not automatically make every alert a disaster.

Question 6 (CISM5-113)

Correct answer: B - Use time-sensitive priority, staffing, escalation, and recovery requirements for the peak period.

Time-sensitive requirements reflect the period of greatest business harm. Annual averages conceal peak exposure, permanent maximum severity wastes resources, and server count is not a business-impact measure.

Question 7 (CISM5-114)

Correct answer: D - A recovery point objective based on acceptable loss of filing transactions.

The RPO defines acceptable data loss and complements the time objective. Alert volume, interview duration, and exercise attendance do not establish the permissible rollback of filing data.

Question 8 (CISM5-115)

Correct answer: B - To sustain prioritized activity while containment, recovery, and restoration proceed.

Continuity sustains essential business activity during disruption while incident teams address the cause and recovery. It does not own investigations, activate for every event, or replace containment decisions.

Question 9 (CISM5-116)

Correct answer: C - Develop and test an alternate access method that does not depend on the affected identity platform.

An effective workaround must avoid the likely failed dependency and be tested. External hosting does not remove identity reliance, more logs do not restore access, and delay defeats continuity objectives.

Question 10 (CISM5-117)

Correct answer: A - Redesign and exercise the process to meet the approved requirement or formally address the gap.

The known gap should be corrected and tested or explicitly accepted by accountable owners. Partial capacity, an unauthorized requirement change, or waiting for a real incident leaves patient-service risk unmanaged.

Question 11 (CISM5-118)

Correct answer: C - Restore the secrets vault before applications that depend on it.

The vault is a prerequisite and must be restored before dependent applications can operate securely. Equal RPOs do not solve order, visibility does not override dependency, and independent sequencing creates conflicts.

Question 12 (CISM5-119)

Correct answer: B - End-to-end validation of access, data, interfaces, transactions, dependencies, and recovery objectives.

Server startup does not prove business usability. End-to-end testing validates the complete recovered service, while host timing, media inventory, and furniture do not demonstrate operational recovery.

Question 13 (CISM5-120)

Correct answer: B - RTO addresses acceptable restoration time, while RPO addresses acceptable data loss measured in time.

RTO concerns how quickly service must return; RPO concerns how much data loss is acceptable. Neither measures staffing or investigation duration, and supplier targets need not equal business objectives.

Question 14 (CISM5-121)

Correct answer: C - Include information sensitivity, strategic impact, trust, scope, urgency, and applicable obligations.

Multidimensional criteria capture the potential strategic impact of one sensitive mailbox. Hardware cost and unstructured judgment are inadequate, while automatic maximum ratings ignore verified context.

Question 15 (CISM5-122)

Correct answer: C - Documented thresholds based on impact, data, scope, urgency, safety, and obligations.

Objective thresholds enable consistent, timely routing to appropriate stakeholders. Final loss is too late, user requests alone are insufficient, and board involvement for every alert creates noise.

Question 16 (CISM5-123)

Correct answer: A - Separate category and severity, then map their combinations to owners, actions, authority, and escalation.

Category identifies incident nature and severity expresses impact and urgency; mapping both improves routing. Title-level severities are unwieldy, repair time is incomplete, and wider email distribution does not resolve ambiguity.

Question 17 (CISM5-124)

Correct answer: A - Map competencies to roles, assign trained personnel and alternates, and retest the gaps.

Role mapping, training, alternates, and retesting address the actual readiness weaknesses. Technical board training, narrower exercises, and outsourced corporate authority do not.

Question 18 (CISM5-125)

Correct answer: C - Use varied scenarios and injects tied to decision, coordination, communication, and recovery objectives.

Varied objective-driven exercises test judgment rather than memory. Removing documentation, relying on one technical metric, or excluding leaders weakens assurance over management response.

Question 19 (CISM5-126)

Correct answer: A - A facilitated tabletop with progressive business and stakeholder injects.

A facilitated tabletop safely tests leadership decisions and cross-functional coordination. A live shutdown creates risk, a scan tests controls, and download counts do not demonstrate capability.

Question 20 (CISM5-127)

Correct answer: B - Create prioritized corrective actions with owners, dates, validation evidence, and retesting.

Accountable actions and retesting turn findings into measurable improvement. Suppression, attendance alone, and exercise completion do not show that identified gaps are resolved.

Question 21 (CISM5-128)

Correct answer: C - An initial determination of incident status, impact, priority, ownership, and routing.

Triage establishes whether reported activity is an incident and how it should initially be handled. Root cause, notification, and redesign require later facts and authorization.

Question 22 (CISM5-129)

Correct answer: B - The telemetry changes because possible integrity and patient-safety impact require urgent triage.

Potentially altered clinical thresholds create immediate safety risk and outweigh blocked scans. Event volume alone is not impact, and waiting for a meeting or proven intent may allow harm.

Question 23 (CISM5-130)

Correct answer: B - Provide a monitored supplier-reporting channel with acknowledgment, intake guidance, and escalation.

A monitored channel supports early, consistent reporting and triage. Proof requirements and buyer investigations delay response, while supplier size does not determine incident relevance.

Question 24 (CISM5-131)

Correct answer: A - Place the process in a safe state using authorized procedures, document actions, and preserve feasible evidence.

Safety and stabilization take priority, while documentation and feasible evidence collection should continue. Continuing unsafe operation is unacceptable, undocumented erasure harms investigation, and the organization retains safety authority.

Question 25 (CISM5-132)

Correct answer: B - Stop the inquiry unless the administrator agrees.

Independent oversight protects evidence and due process while appropriate specialists coordinate personnel and legal issues. Self-investigation creates conflict, consent is not the governing condition, and public attribution is premature.

Question 26 (CISM5-133)

Correct answer: D - Evidence integrity and provenance may be challenged because custody was not maintained.

Missing integrity and handling records weaken evidentiary reliability. They do not predetermine attribution, define a disaster, or justify unrelated recovery changes.

Question 27 (CISM5-134)

Correct answer: A - Coordinate legal, privacy, human resources, and investigators on lawful, proportionate collection and preservation.

Cross-border collection requires specialist coordination to establish authority, proportionality, handling, and preservation. A universal rule may be unlawful, supervisors are not legal decision makers, and public identification is premature.

Question 28 (CISM5-135)

Correct answer: A - The balance among continuing harm, safety, business impact, evidence, authority, and recovery options.

Containment is a risk-based decision balancing harm reduction with operational, evidentiary, safety, authority, and recovery needs. Preference, precedent, and document length alone are insufficient.

Question 29 (CISM5-136)

Correct answer: C - Revoke the affected key, isolate the broker connection, preserve records, and monitor for related abuse.

Targeted revocation stops the confirmed path while limiting business impact and preserving evidence. Delay permits harm, full shutdown may be disproportionate, and log deletion impairs investigation.

Question 30 (CISM5-137)

Correct answer: B - Implement tested, monitored, business-approved restrictions with an expiration date and tracked replacement.

Time-bounded compensating measures balance reduced exposure with operations until remediation. Convenience does not justify risk, indefinite acceptance lacks accountability, and wholesale disconnection may create safety issues.

Question 31 (CISM5-138)

Correct answer: A - Issue an approved holding statement describing verified impact, response activity, and update channels.

A factual holding statement addresses stakeholder needs without spreading unsupported claims. Confirming rumors or theories is premature, while prolonged silence can worsen confusion.

Question 32 (CISM5-139)

Correct answer: D - A coordinated legal, privacy, contract, insurance, and business assessment of verified facts and applicable duties.

Notification assessment should start promptly using verified facts and applicable obligations. A universal deadline may be wrong, asserted harm may be unsupported, and full root cause is not required to begin analysis.

Question 33 (CISM5-140)

Correct answer: C - Create audience-specific updates from one verified incident record, aligned with decision needs and cadence.

A common verified source maintains consistency while tailored reporting supports each role. Uniform detail creates noise, independent estimates conflict, and purely reactive communication weakens oversight.

Question 34 (CISM5-141)

Correct answer: D - Activate crisis coordination for operational, executive, government, partner, and public communication needs.

Widespread essential-service impact requires enterprise crisis coordination while technical response continues. Waiting delays action, individual briefings create inconsistency, and operational ownership does not end the incident.

Question 35 (CISM5-142)

Correct answer: D - Revoke unauthorized sessions, secure recovery paths, remediate the weakness, and validate removal of persistence.

Eradication must address all known access paths and enabling weaknesses. Removing one artifact is incomplete, delay preserves unauthorized access, and routine-ticket treatment would close the incident prematurely.

Question 36 (CISM5-143)

Correct answer: B - To confirm functionality, integrity, security, dependencies, and agreed business outcomes before normal use.

Validation establishes that the service is trustworthy and fit for business use. It cannot prove zero future risk, replace monitoring, or transfer organizational acceptance.

Question 37 (CISM5-144)

Correct answer: D - Maintain restrictions until reconciliation and recovery criteria are satisfied and the designated business owner accepts service.

Availability alone does not prove integrity. Restrictions should remain until validation and business acceptance; suppliers cannot accept organizational risk, and reaching the RTO does not override failed reconciliation.

Question 38 (CISM5-145)

Correct answer: C - Restore service gradually with enhanced recurrence monitoring

Controlled return with enhanced monitoring provides assurance during stabilization. Disabling visibility or deleting indicators is premature, while waiting for elimination of all risk is impractical.

Question 39 (CISM5-146)

Correct answer: D - Reassess the risk, revise response criteria and safeguards, train relevant roles, and test voice-channel scenarios.

The review should update risk assumptions, safeguards, procedures, training, and exercises based on observed behavior. No change or reminders alone are incomplete, while a blanket ban may be disproportionate.

Question 40 (CISM5-147)

Correct answer: C - Examine design, approvals, workload, training, oversight, and contributing factors while using proper personnel channels.

A systemic review identifies sustainable improvements and supports candor. Excluding owners, public blame, or cancellation leaves organizational weaknesses unresolved.

Question 41 (CISM5-148)

Correct answer: D - Certificate governance failed in ownership, renewal, and escalation

The failed lifecycle process explains why a predictable expiration caused the incident. Error messages and calls are symptoms, while restarts are response actions.

Question 42 (CISM5-149)

Correct answer: D - Verbal completion claims without evidence.

A governed register turns lessons into accountable and verifiable improvement and exposes residual-risk decisions. Time, unsupported claims, and narrow review do not demonstrate completion.

Question 43 (CISM5-150)

Correct answer: A - Impact, response, recurrence, recovery, and remediation trends

Balanced measures connect operations to business consequence, timeliness, repeated causes, recovery, and improvement. Alert, labor, or closure counts alone can hide deteriorating risk.